

Contents

1. Exercise Overview 4

2. Exercise Objectives 4

3. Scenario Narrative 4

4. Exercise Injects 4

 Inject 1: Suspicious Endpoint..... 4

 Inject 2: Multiple Systems Affected 5

 Inject 3: Potential Lateral Movement 5

 Inject 4: Backup Concern 5

 Inject 5: Ransom Demand 6

 Inject 6: Business Impact..... 6

 Inject 7: Media and Customer Pressure 6

 Inject 8: Recovery Decision..... 7

5. Final Exercise Inject..... 7

6. Facilitator Guide 8

 Before the Exercise..... 8

 Ground Rules..... 8

 Facilitator Responsibilities..... 8

7. Observer Evaluation 8

8. Key Metrics 9

 Detection 9

 Response 9

 Recovery 9

 Governance 9

9. After-Action Report Template.....10

 Executive Summary10

 Objectives Assessment.....10

 What Went Well10

 What Did Not Go Well.....11

 Findings and Gaps.....11

 Corrective Action Plan.....11

 Policy and Procedure Improvements11

 Technology Improvements11

 Training and Awareness Improvements12

Lessons Learned	12
Final Recommendations.....	12
Exercise Closeout.....	12

RANSOMWARE INCIDENT RESPONSE TABLETOP EXERCISE

Complete Tabletop Exercise Package

Field	Details
Exercise Type	Discussion-based tabletop exercise
Scenario	Ransomware incident
Duration	2 to 2.5 hours
Focus	Incident response, crisis management, business continuity and recovery
Audience	SOC, IT, Incident Response, GRC, Management, Legal, HR, Communications and Business Continuity

1. Exercise Overview

This tabletop exercise analyze a ransomware incident that can be form from an compromise system into a whole organization impact. All Participants are mandatory to make their practices and decisions as per existing policies of incident response, business continuity, disaster recovery and crisis communication policies.

2. Exercise Objectives

- Demonstrate the organization's incident response process.
- Identify roles and responsibilities during a ransomware incident.
- Test escalation and incident classification procedures.
- Assess communication and crisis-management processes.
- Evaluate containment and eradication decision-making.
- Test backup and disaster recovery procedures.
- Identify legal, regulatory, contractual and reporting considerations.
- Test coordination between technical, management and business teams.
- Identify gaps in policies, procedures, technology, people and decision-making.
- Produce actionable improvement items after the exercise.

3. Scenario Narrative

It is a normal working day in an organization, at 09:15 AM. The organization routine tasks are operated normally as per routine. Multiple employees are working from Head office and their homes remotely. Critical business applications, file servers, Active Directory, email, ERP and customer facing systems are every critical application operating as normally.

Suddenly SOC team receives an alert from the endpoint security platform which indicating that there is something suspicious activity is going on an employee endpoint workstation. The compromised user reports that files names are changes in a strange way and some of them are not able to opened.

During Initial investigation it is observed:

- Multiple files have been encrypted.
- PowerShell executed with encoded commands.
- The endpoint communicated with an unfamiliar external IP address.
- Several administrative tools were launched.
- The user's account accessed multiple internal systems.
- There are indications of credential theft.
- No confirmed evidence of data exfiltration has yet been established.

Initial classification: High Severity Security Incident.

4. Exercise Injects

Inject 1: Suspicious Endpoint

Time: 09:15

Information provided:

- One workstation appears infected.

- Multiple files have been encrypted.
- PowerShell activity is present.
- The user account is still active.

Discussion questions:

- What is the first action?
- Who owns the incident?
- What is the severity?
- Should the workstation be isolated?
- Who must be notified?
- What evidence needs to be preserved?
- Do we activate the Incident Response Team?

Inject 2: Multiple Systems Affected

Time: 09:35

Information provided:

- Three additional systems show similar activity.
- A Finance file server is affected.
- Users report that shared files cannot be opened.
- A privileged administrative account was used shortly before encryption began.

Discussion questions:

- Does the severity change?
- Should network segmentation be activated?
- Should privileged accounts be disabled?
- Who can authorize shutting down affected systems?
- What systems are considered critical?
- How will business operations continue?

Inject 3: Potential Lateral Movement

Time: 10:00

Information provided:

- Authentication activity suggests possible lateral movement.
- The compromised administrative account may have been used across systems.
- It is not yet confirmed whether Domain Administrator privileges were obtained.

Discussion questions:

- What is the containment strategy?
- Should privileged credentials be reset?
- How will compromised accounts be identified?
- What logs should be reviewed?
- Do critical servers need to be isolated?

Inject 4: Backup Concern

Time: 10:25

Information provided:

- The latest Finance file-server backup completed successfully.
- The backup environment has also generated unusual authentication alerts.
- The team cannot immediately confirm whether backups are safe.

Discussion questions:

- Can the organization trust its backups?
- Who validates backup integrity?
- What is the last known-good backup?
- What are the RTO and RPO?
- Can restoration begin while investigation continues?
- What is the recovery priority order?

Inject 5: Ransom Demand

Time: 10:45

Information provided:

- A ransom note appears on multiple systems.
- Attackers claim that sensitive information was copied.
- The note gives a 72-hour deadline and demands cryptocurrency.

Discussion questions:

- Who decides whether the organization engages with the attacker?
- Who contacts law enforcement?
- When is Legal involved?
- Are regulatory notifications required?
- What evidence should be preserved?
- Who communicates with customers and employees?
- How will the organization verify alleged data theft?

Inject 6: Business Impact

Time: 11:15

Information provided:

- Finance cannot access the ERP system.
- Customer support is affected because the CRM is unavailable.
- The business estimates that approximately 60% of normal operations are disrupted.

Discussion questions:

- Which systems should be restored first?
- Who determines business priorities?
- Is the Business Continuity Plan activated?
- Are manual processes available?
- When does the incident become a business crisis?

Inject 7: Media and Customer Pressure

Time: 11:35

Information provided:

- An employee posts on social media that company systems have been hacked.
- Customers ask whether personal information has been compromised.
- A journalist contacts Communications for confirmation.

Discussion questions:

- Who is authorized to speak publicly?
- What can employees share?
- What is the customer communication process?
- How do Legal, Security and Communications coordinate?
- How will misinformation be handled?

Inject 8: Recovery Decision

Time: 12:00

Information provided:

- A known-good backup from three days earlier is identified.
- The backup is scanned and appears clean.
- Forensics indicates attackers may have maintained access for approximately two weeks.

Discussion questions:

- Is the backup safe enough to restore?
- How will continued attacker access be ruled out?
- Should credentials be reset before restoration?
- Which systems should be restored first?
- Who approves recovery?
- What criteria determine incident closure?

5. Final Exercise Inject

In the final Exercise technical team reports that critical systems have been compromised, monitoring has been heightened, credentials have been changed and no further ransomware activity has been detected for 24 hours. The investigation into possible data theft is still ongoing.

Final discussion:

- Is the incident closed?
- Who makes that decision?
- What conditions must be met before closure?
- What evidence must be retained?
- Who needs a final incident report?
- What regulatory or contractual obligations remain?
- What lessons need to be captured?
- What security improvements should be prioritized?

6. Facilitator Guide

Before the Exercise

- Define exercise objectives and scope.
- Confirm participants and roles.
- Identify the Incident Response Plan, Business Continuity Plan and Disaster Recovery Plan.
- Prepare contact lists and fictional incident artifacts.
- Confirm the exercise is authorized.
- Explain that the exercise is not a test of individual performance.

Ground Rules

- Assume the scenario is real.
- Make decisions using existing procedures.
- State assumptions clearly.
- Identify dependencies.
- Avoid solving problems outside the scope of the exercise.
- Record gaps and unresolved questions.

Facilitator Responsibilities

- Introduce the scenario and release injects progressively.
- Challenge assumptions with questions such as 'How do you know that?' and 'Who is responsible for that decision?'
- Track decisions, owners, timing, rationale and outstanding actions.
- Observe communication, escalation, ownership and documentation.
- Avoid solving the problem for participants. Ask what the current procedure says and who normally makes the decision.

7. Observer Evaluation

Area	Green	Amber	Red
Incident Detection	Clear process	Some delays	Major gaps
Escalation	Immediate	Some uncertainty	No clear process
Incident Ownership	Clearly defined	Some confusion	No clear owner
Containment	Defined actions	Partial process	No clear strategy
Evidence Preservation	Defined	Inconsistent	Not defined
Communication	Clear	Some delays	Conflicting/unclear
Crisis Management	Coordinated	Some gaps	Poor coordination
Business Continuity	Defined	Partially defined	Not available
Backup/Recovery	Tested	Some uncertainty	Unknown
Legal/Regulatory	Clear	Some uncertainty	No defined process
Third-Party Management	Defined	Partial	Not defined
Customer Communication	Defined	Some uncertainty	No process
Decision Making	Clear authority	Some confusion	No authority
Documentation	Strong	Partial	Poor
Post-Incident Review	Defined	Informal	Not defined

8. Key Metrics

Detection

- Time to detect
- Time to classify
- Time to escalate

Response

- Time to isolate endpoint
- Time to disable compromised accounts
- Time to activate the IR team
- Time to contain lateral movement

Recovery

- Time to identify clean backup
- Time to begin restoration
- Time to restore critical services
- Actual RTO vs defined RTO

Governance

- Time to notify management
- Time to engage Legal
- Time to engage Communications
- Time to determine regulatory requirements

9. After-Action Report Template

Exercise Date:Exercise Name:Facilitator:

Exercise Duration:

Participants:

Business Units:

Executive Summary

Exercise objective:

Overall observations:

Major strengths:

Major gaps:

Objectives Assessment

Objective	Result	Observation
Incident detection	Green / Amber / Red	
Incident escalation	Green / Amber / Red	
Containment	Green / Amber / Red	
Communication	Green / Amber / Red	
Business continuity	Green / Amber / Red	
Recovery	Green / Amber / Red	
Crisis management	Green / Amber / Red	
Legal/regulatory response	Green / Amber / Red	

What Went Well

What Did Not Go Well

Findings and Gaps

ID	Finding	Risk/Impact	Owner	Priority
F-01				High/Medium/Low
F-02				High/Medium/Low
F-03				High/Medium/Low

Corrective Action Plan

Action ID	Gap	Corrective Action	Owner	Due Date	Status
CAP-01					Open
CAP-02					Open
CAP-03					Open

Policy and Procedure Improvements

- Incident Response Plan
- Ransomware Response Procedure
- Crisis Management Plan
- Business Continuity Plan
- Disaster Recovery Plan
- Backup Policy
- Access Control Policy
- Privileged Access Management Procedure
- Communication/Media Procedure
- Data Breach Notification Procedure
- Third-Party Incident Management Procedure

Technology Improvements

- EDR coverage
- SIEM monitoring
- Network segmentation
- MFA
- Privileged Access Management
- Backup isolation
- Immutable backups
- Email security
- Identity monitoring
- Vulnerability management
- Endpoint hardening
- Logging and retention
- Threat intelligence

Training and Awareness Improvements

- SOC analysts
- IT administrators
- Incident responders
- Management
- Employees
- Help desk
- Legal
- Communications
- Business continuity teams

Lessons Learned

What should we continue doing?

What should we stop doing?

What should we start doing?

Final Recommendations

Prioritize corrective actions based on risk, business impact, regulatory requirements, feasibility, ownership and timeline. Each action should have a clearly assigned owner, target completion date, required resources, success criteria and validation method.

Exercise Closeout

Exercise completed: Yes / No

approved by:

Date:

Next tabletop exercise:

Follow-up review date: